

API Security Risk Analysis Report

Internship:

Future Interns – Cyber Security Task 3

Project:

API Security Risk Analysis

Submitted By:

Girra Madhumitha

Introduction

Application Programming Interfaces (APIs) are essential components of modern software applications. They enable communication between web applications, mobile applications, cloud services, and third-party integrations. As organizations increasingly rely on APIs to exchange and process data, securing these interfaces has become a critical aspect of cybersecurity.

API security focuses on protecting data, services, and functionality exposed through API endpoints. Insecure APIs may lead to unauthorized access, excessive data exposure, data breaches, and abuse of system resources. Attackers often target APIs because they directly interact with application data and business logic.

This project performs a read-only API Security Risk Analysis using a public testing API. The objective is to evaluate the API from a security perspective, identify common security risks, assess their potential business impact, and recommend appropriate remediation measures. The analysis follows ethical security practices and focuses on observation and risk assessment rather than exploitation.

Objectives

- Analyze a public API using Postman
- Inspect API responses and exposed data
- Identify common API security risks
- Assess business impact of identified risks
- Classify risk severity levels
- Provide security recommendations and remediation steps

Tools Used

The following tools were used during the API Security Risk Analysis:

- Postman – API testing and response inspection
- JSONPlaceholder – Public testing API
- GitHub – Project documentation and version control
- Microsoft Word – Report preparation
- Browser – API documentation review and research

Scope of Assessment

This assessment was conducted on the public testing API provided by JSONPlaceholder.

API Tested:

<https://jsonplaceholder.typicode.com/users>

Scope Included:

- API endpoint review
- Response analysis
- Authentication assessment
- Data exposure review
- Security risk identification

Scope Excluded:

- Exploitation attempts
- Denial-of-Service testing
- Authentication bypass testing
- Any activity that could affect service availability

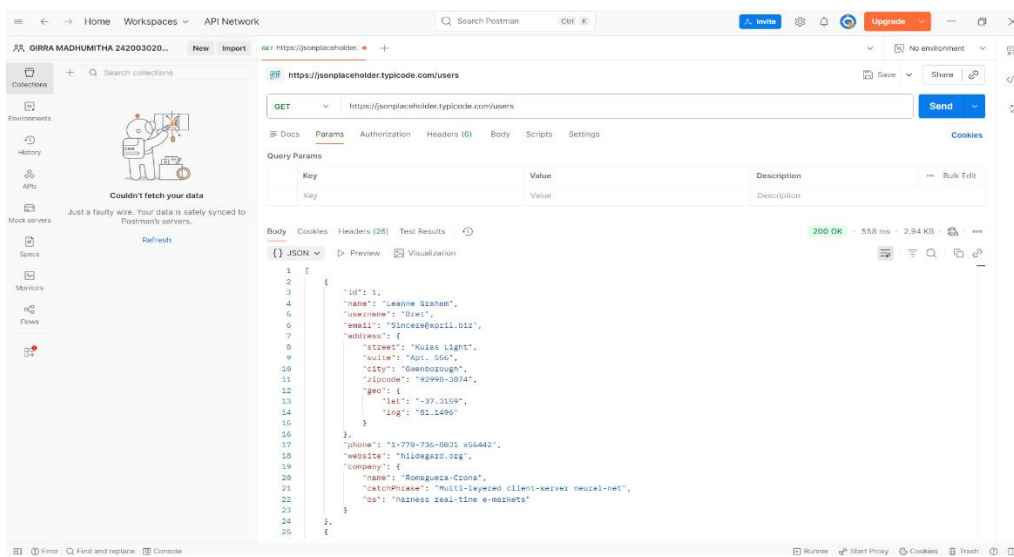
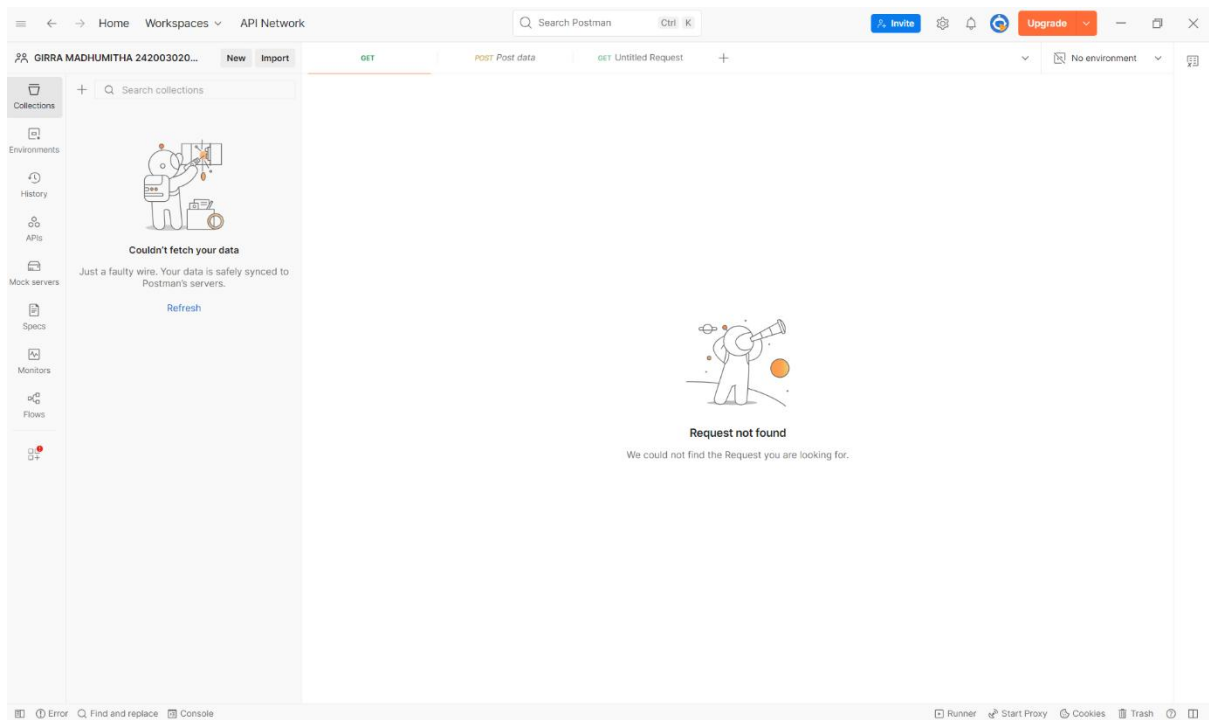
The assessment followed ethical and read-only testing practices.

Methodology

The following methodology was followed during the assessment:

1. Selected a public API designed for testing and learning.
2. Reviewed available API documentation.
3. Sent API requests using Postman.
4. Inspected response data and exposed fields.
5. Evaluated authentication and access controls.
6. Identified potential security risks.
7. Assessed business impact and severity levels.
8. Documented findings and remediation recommendations.

This methodology follows a structured approach commonly used in API security reviews and consulting engagements.



Risk Findings

1. Open / Unauthenticated Endpoint

Severity: Medium

Observation:

The API endpoint was accessible without requiring any authentication mechanism such as an API key, access token, or user login.

Business Impact:

Publicly accessible endpoints may allow unauthorized users to access information without verification. In real-world applications, this could increase the risk of data exposure and misuse.

Recommendation:

Implement secure authentication mechanisms such as API Keys, OAuth 2.0, or JWT-based authentication to ensure only authorized users can access protected resources.

2. Excessive Data Exposure

Severity: Medium

Observation:

The API response returned multiple user-related fields including names, email addresses, phone numbers, addresses, websites, and company information.

Business Impact:

Exposing unnecessary information increases privacy risks and may provide useful intelligence for phishing attacks, social engineering campaigns, and reconnaissance activities.

Recommendation:

Return only the minimum data required for business functionality and follow the principle of least privilege.

3. Potential Missing Rate Limiting

Severity: Low

Observation:

No visible rate-limiting controls were observed during basic API testing.

Business Impact:

Attackers may abuse the API through automated requests, large-scale data collection, or excessive traffic generation.

Recommendation:

Implement API rate limiting, monitoring, and request throttling to prevent abuse.

4. Missing Authentication Controls

Severity: Medium

Observation:

The endpoint allowed access to user-related information without validating user identity or authorization requirements.

Business Impact:

In production environments, similar behavior may lead to unauthorized access to sensitive information and privacy concerns.

Recommendation:

Require authentication and authorization checks before providing access to user-related resources.

POSTMAN

GIRRA MADHUMITHA 242003020... New Import

GET https://jsonplaceholder.typicode.com/users

Save Share

GET https://jsonplaceholder.typicode.com/users

Docs Params Authorization Headers (6) Body Scripts Settings

Body Cookies Headers (26) Test Results Visualization

200 OK 558 ms 2.94 KB

```
1 [
2   {
3     "id": 1,
4     "name": "Leanne Graham",
5     "username": "Bret",
6     "email": "Sincere@april.biz",
7     "address": {
8       "street": "Kulas Light",
9       "suite": "Apt. 556",
10      "city": "Gwenborough",
11      "zipcode": "92998-3874",
12      "geo": {
13        "lat": "-37.3159",
14        "lng": "81.1496"
15      }
16    },
17    "phone": "1-778-736-8031 x56442",
18    "website": "hildegard.org",
19    "company": {
20      "name": "Romaguera-Crona",
21      "catchPhrase": "Multi-layered client-server neural-net",
22      "bs": "harness real-time e-markets"
23    }
24  },
25  {
26    "id": 2,
27    "name": "Ervin Howell",
28    "username": "Antonette",
29    "email": "Shanna@melissa.tv",
30    "address": {
31      "street": "Victor Plains",
32      "suite": "Suite 879",
```

Runner Start Proxy Cookies Trash

POSTMAN

GIRRA MADHUMITHA 242003020... New Import

GET https://jsonplaceholder.typicode.com/users

Save Share

GET https://jsonplaceholder.typicode.com/users

Docs Params Authorization Headers (6) Body Scripts Settings

Body Cookies Headers (26) Test Results Visualization

200 OK 558 ms 2.94 KB

Key	Value
Date	Fri, 29 May 2026 16:36:06 GMT
Content-Type	application/json; charset=utf-8
Content-Length	1847
Connection	keep-alive
access-control-allow-credentials	true
Cache-Control	max-age=43200
Content-Encoding	gzip
etag	W/"160d-1eMSxwJRfnVLRBmYJSbCUJZ1qQ"
expires	-1
nel	{"report_to":"heroku-nel","response_headers":["Via"],"max_age":3600,"success_fraction":0...
pragma	no-cache
report-to	{"group":"heroku-nel","endpoints":[{"url":"https://nel.heroku.com/reports?s=oggGsf0f1M...
reporting-endpoints	heroku-nel="https://nel.heroku.com/reports?s=oggGsf0f1MAXtgC%2FDYoOSko%2FaQ...
Server	cloudflare
vary	Origin, Accept-Encoding
via	2.0 heroku-router

Runner Start Proxy Cookies Trash

Risk Summary

Risk ID	Risk Name	Severity
R1	Open/Unauthenticated Endpoint	Medium
R2	Excessive Data Exposure	Medium
R3	Potential Missing Rate Limiting	Low
R4	Missing Authentication Controls	Medium

Remediation Plan

The following recommendations are suggested to improve API security:

- Implement strong authentication mechanisms such as OAuth 2.0 or JWT.
- Restrict access to sensitive endpoints.
- Apply the principle of least privilege to API responses.
- Limit exposure of unnecessary user information.
- Implement API rate limiting and traffic monitoring.
- Maintain detailed API logging and auditing.
- Conduct regular API security assessments.
- Follow OWASP API Security best practices.

Conclusion

This API Security Risk Analysis evaluated a public API endpoint using read-only testing techniques. The assessment identified several common API security concerns including unauthenticated access, excessive data exposure, potential missing rate limiting, and insufficient authentication controls.

Although the analyzed API is intentionally designed for testing and educational purposes, the findings demonstrate security issues that could pose significant risks in production environments. Organizations should implement strong authentication, minimize exposed data, enforce rate limiting, and regularly review API security controls.

This project highlights the importance of API security in modern applications and demonstrates how security analysts can identify risks, assess business impact, and provide remediation recommendations through structured security assessments.